State Capitol P.O. Box 2062
Albany, NY 12220-0062
www.its.ny.gov

New York State Information Technology Policy	No: **NYS-P13-001**
IT Policy: **Information Security Exception Policy**	**Updated: 07/13/2026**
	Issued By: NYS Office of Information Technology Services **Owner:** Chief Information Security Office

1.0 Purpose and Benefits

The purpose of this policy is to outline the process for obtaining an exception regarding compliance with a published information security policy or standard issued by the New York State (NYS) Office of Information Technology Services (ITS).

2.0 Authority

Section 103(10) of the State Technology Law provides ITS with the authority to establish statewide technology policies, including technology and security standards. Section 2 of Executive *Order No. 117*[1], established January 2002, provides the State Chief Information Officer with the authority to oversee, direct and coordinate the establishment of information technology policies, protocols, and standards for State government, including hardware, software, security, and business re-engineering. Details regarding this authority can be found in NYS ITS Policy, *NYS-P08-002 Authority to Establish Enterprise Information Technology Policies, Standards, and Guidelines.*

3.0 Scope

This policy applies to all "State Entities" (SE), defined as "State Government" entities in Executive Order 117[1] or "State Agencies" in Section 101 of the State Technology Law. This includes employees of the SE and ITS and all third parties (such as local governments, consultants, vendors, and contractors) that use or access any IT resource for which the SE or ITS has administrative responsibility, including systems managed or hosted by third parties on behalf of the SE. While an SE may adopt a different policy, it must include the requirements set forth in this one. Where a conflict exists between this policy and an SE's policy, the more restrictive requirement will take precedence.

4.0 Information Statement

An exception may be granted by the Chief Information Security Officer (CISO) of ITS, or their designee, when there is no legitimate method to accomplish a business objective in a manner compliant with NYS security policies and standards. Justification for approval of policy or standard exceptions include, but are not limited to:

- Implementation of a solution with equivalent or superior protection to the requirements in the NYS policy or standard issued by the ITS CISO.
- Implementation of a solution with equivalent protection to the requirements in the CISO policy or standard.
- Impending retirement of a system.
- Inability to implement the requirements of a policy or standard due to some limitation (e.g., technical constraint, business limitation or statutory requirement).

Exceptions are reviewed and considered on a case-by-case basis and approval should not be assumed. Exceptions may be denied based upon the risks posed to State information technology environments. If the non-compliance with the information security policy or standard is due to a superior solution, an exception is still required.

Exceptions that are granted will be for a limited period of time. Upon expiration of the exception, a one-time extension may be requested, if it is still required.

[1] All references to Executive Order 117 refer to that which was originally issued by Governor George E. Pataki on January 28, 2002 and continued by Executive Order 5 issued by Governor Eliot Spitzer on January 1, 2007, Executive Order 9 issued by Governor David A. Patterson on June 18, 2008, Executive Order 2 issued by Governor Andrew M. Cuomo on January 1, 2011 and Executive Order 6 issued by Governor Kathy Hochul on October 8, 2021.

The exception request must be submitted on a completed Exception Request Form and must include:

- Description of the non-compliance (should include the specific policies or standards that are not be able to be met);
- Assessment of risks, if any, associated with non-compliance;
- Expected remediation date;
- Existing compensating controls for managing the risks associated with non-compliance, including, but not limited to: isolated network, access controls, multi-factor authentications (MFA). Unacceptable controls include, but are not limited to: standard data center inclusion, Endpoint Detection and Response (EDR), potential controls not yet implemented;
- Any ITSM numbers, demand numbers, or project numbers;
- A list of all devices in scope of the exception and a network diagram detailing the environment and data flow; and
- Detailed corrective action plan or mitigation plan – should include milestones and progress review dates.

The Exception Request Form must be signed by the following:

- Information/Business Owner;
- Cyber Risk Coordinator (CRC) or Information Security Officer/ Designated Security Representative (ISO);
- Deputy Commissioner for Technology (DCT); and, where applicable;
- Commissioner/Executive Deputy Commissioner (or authorized designee).

Upon submission of the Exception Request Form, the CISO, or their designee, will contact the requester to confirm receipt and request additional information, if needed. Once all required information has been received, the CISO or designee will either grant or deny the request.

Upon approval, the CISO, or their designee, will send the approved Exception Request Form to the requestor. If the request is denied, the Exception Request Form will be returned with a brief explanation of why the request was denied.

In the event that the request is denied, the Commissioner/Executive Deputy Commissioner and the CIO/DCT who signed the Exception Request Form may request a meeting with the ITS CIO and the CISO, the Director of Security and

Intelligence or their designees, to discuss the circumstances giving rise to the request and means of addressing those circumstances.

5.0 Compliance

This policy shall take effect upon publication. Compliance is required with all enterprise policies and standards. ITS may amend its policies and standards at any time; compliance with amended policies and standards is required.

6.0 Definitions of Key Terms

Except for terms defined in this policy, all terms shall have the meanings found in http://www.its.ny.gov/glossary.

7.0 Contact Information

Submit all inquiries and requests for future enhancements to the policy owner at:

Chief Information Security Office
Reference: NYS-P13-001
NYS Office of Information Technology Services
31 British American Blvd.
Latham, NY 12110
Telephone: (518) 242-5200
Email: CISO@its.ny.gov

Statewide technology policies, standards, and guidelines may be found at the following website: https://its.ny.gov/policies

8.0 Revision History

This policy should be reviewed consistent with the requirements set forth in *NYS-P08-002 Authority to Establish Enterprise Information Technology Policies, Standards, and Guidelines*.

Original Release Date: 10/18/2013		
Date	**Description of Change**	**Reviewer**
10/18/2013	Original Policy Release	Thomas Smith, Chief Information Security Officer
09/19/2014	Policy Review – no changes	Deborah A. Snyder, Acting Chief Information Security Officer
02/10/2017	Update to Scope, contact information and rebranding	Deborah Snyder, Deputy Chief Information Security Officer
02/07/2020	Updated Authority, Scope, and Contact Information	Karen Sorady, Acting Chief Information Security Officer
05/20/2021	Updated Scope language	Karen Sorady, Acting Chief Information Security Officer
10/11/2022	Scheduled review and update, removal of one year limitation, grammatical changes, and other minor revisions.	Chris DeSain, Chief Information Security Officer
07/13/2026	Minor language changes for clarification, Updated Contact Information	Chris DeSain, Chief Information Security Officer

9.0 Related Documents

NYS-P13-001 Information Security Exception Policy Form